

Day 2 — System Security & Compliance · Facilitator Guide

Companion to `labs/day-02-security-compliance.md` . Facilitator-only — do not hand to participants.

Framing note

Today's job is to run a **STRIDE threat-model pass** at the architecture level, translate the results into revised security and compliance NFRs, and add §3 of the TCD. The discipline: the TPM is not the security expert — they drive the right conversation and produce a starting threat model security can validate.

Activity 1 — STRIDE Calibration on a Public Example

Cues:

- Nearly every triad will miss **Repudiation** in this exercise. It's the least intuitive letter. Surface it.
- Some triads will conflate "security" with "authentication." STRIDE forces a wider lens.

Answer key / watch-for (password-reset flow):

- The **magic-link** mechanism has a Repudiation question worth surfacing: how do you prove a user clicked the link they later deny? (Log link issuance + click with timestamp + IP.)
- Predictable finds: Spoofing (email enumeration / requesting a reset for someone else's email), Information disclosure (leaking whether an account exists).
- Under-detected: Tampering (link/token not bound to the requesting session), Elevation (reset flow that skips step-up on a privileged account), DoS (unbounded reset requests as an email-bomb vector).
- The most-missed is Repudiation — treat its absence as the tell that the triad stopped at "auth."

Activity 2 — STRIDE Pass on Your PRD Feature

Cues:

- Triads that find only Spoofing and Information Disclosure haven't worked the harder letters; push toward T and R.
- "TLS" is not a mitigation; it's a hint. Force the specific control with version, scope, and verification.

Activity 3 — Compliance Frame + Updated NFRs

Cues:

- "No compliance applies" is almost never true. Push toward SOC 2 by default for B2B SaaS.
- Watch for revised NFRs that just renamed the original — every NFR should reference a specific threat or control.

Activity 4 — Security Stakeholder Conversation Prep

Cues:

- "Tell us about security" is a question that surrenders the conversation. Push for specific scopes, controls, and precedents.
- The AI cross-check is useful only if the prompt loads the actual brief; coach the Critique-hat pattern.

Facilitator reflection prompts (end of day)

- Which triad caught the most subtle threat? Surface as a positive example.
- Which triad's mitigations are most boilerplate? Coach tomorrow morning.
- Did anyone skip Repudiation in their pass? Most do — check.
- Did the cohort handle the AI re-introduction with discipline, or did they over-rely?